STHIROS
Strategy. Risk. Cyber. AI.



Closing email spoofing and data classification gaps for a prominent banking services company

A prominent banking services company engaged Sthiros for a comprehensive Information Security Management System audit, spanning data protection, incident management, and email and mobile security.

Client	Service	Sector	Geography
A Prominent Banking Services Company	**Information Security Management System (ISMS) Audit**	**Banking & Financial Services**	**Global**

The Challenge:

When data protection, incident response, and email security all have gaps at once

This banking services company needed a comprehensive assessment of information security risks and control effectiveness to align with ISMS best practices and regulatory requirements, spanning data classification, incident management, and email and mobile security.

Data Protection & Classification Gaps

Data classification and indexation for DLP was incomplete, with maker-checker controls missing and unmasked customer data shared in third-party reports.

Incident & Risk Management Deficiencies

Incident management lacked severity classification and ageing tracking, with no formal monitoring process or periodic technical risk review in place.

Email & Mobile Security Weaknesses

DKIM was not implemented and DMARC was unconfigured, while MDM users could still access web browsers, creating a live data leakage risk.

The Solution:

A structured ISMS audit across three real fronts

Sthiros ran a comprehensive ISMS audit covering the full security assessment scope, an email security deep dive, and a DLP and MDM framework build, closing gaps at the control level rather than issuing a generic checklist.

Every recommendation was implemented, not just documented, from email authentication protocols to a four-tier data classification framework underpinning DLP policy.

The Methodology

1

Security Assessment Scope

IS policy and ISMS controls, R&R and SOD validation, management reporting, AUP, data transfer, mobile device policy, user access controls, physical security, and encryption reviewed end-to-end.

2

Email Security Deep Dive

SPF, DMARC, and DKIM configuration reviewed and implemented, alongside Office 365 email auditing parameters and new relay and throttling policies.

3

DLP & MDM Framework

A four-tier data classification framework designed, with DLP policy built across endpoints, email, and cloud, and MDM containerisation deployed for BYOD security.

What This Means

Classify data before you protect it.

Close the email spoofing gap.

Turn incidents into a process.

Outcomes

10

Security assessment areas reviewed

Spanning policy, access controls, physical security, and encryption.

3

Email authentication protocols implemented

SPF, DMARC, and DKIM deployed to close a previously open email spoofing risk.

4

Data classification tiers established

Restricted, Confidential, Internal, and Public, underpinning the new DLP policy.

4 Months

Engagement duration

From risk assessment through to DLP and MDM implementation.

Get in touch

Is your data protected by policy, or by design?

Speak to Sthiros about what a structured ISMS audit can unlock for your information security posture.

Connect with us:
sthiros.com

STHIROS
Strategy. Risk. Cyber. AI.